

OrderScan Backend Audit

Every problem found and repaired in the order-extraction backend, written for people who need to know what was wrong and what it would have cost — not how it was coded.

Completed 16 September 2026 Scope Backend + extraction + admin UI Latest commit 86a4dfa

33 PROBLEMS FIXED	342 AUTOMATED TESTS	65 BACKEND ENDPOINTS COVERED	0 TYPE ERRORS
---	---	--	-------------------------------------

01 — WHAT THIS COVERS

A day spent finding what nobody could see

Almost none of the problems below showed up on screen. That is what made them worth hunting. A page looked fine, a button said “Saved”, a report showed a number — and underneath, the work had not actually happened.

The system reads order screenshots, pulls the customer details out of them, and stores them. Around that sit the money parts: partner commissions, brand invoices, payouts, plans and billing. This review went through all of it.

Each problem below says what was wrong and what it could have cost you. They are grouped by the kind of mistake, because the same kind kept appearing in different places.

Five that could have caused real damage

01

The payment ledger mixed every company's money together

`reconcile.functions.ts · getPaymentLedger`

DATA LEAK BETWEEN CUSTOMERS

The payment ledger page asks five questions of the database: who is owed what, what has been paid, what the brand was invoiced, and what came back. **Not one of those five filtered by company.**

Only a database-level safety net stood between one customer's ledger and another's. Every other money screen in the system filters properly — this one did not filter at all.

There was a second edge on it: the brand invoice lookup expected to find at most one invoice for the month. The moment a second company had an invoice for that same month, the page would have stopped working entirely.

02

Money reports showed zero instead of an error

`brand.functions.ts & reconcile.functions.ts`

WRONG NUMBERS, SILENTLY

The agency earnings report and the payment ledger both ask the database several questions at once. If one of those questions failed, the code quietly treated the answer as “nothing found”.

The result looked exactly like a quiet month: **zero revenue, zero cost, zero margin — with no warning at all.** For a number somebody bills against, that is the worst possible way to fail.

Both reports now say which part failed and stop, rather than showing a confident zero.

03

Payout runs hid their own failures

payouts.functions.ts · generate & bulk mark paid

PARTNERS SILENTLY MISSED

Generating partner payouts for a month writes one record per partner. The code counted a record only when it succeeded — and did nothing at all when it failed.

So a run that failed half its writes still came back with a tidy set of numbers, and **nobody could tell which partners had been left out.**

Both functions now return a list of exactly which partners failed and why.

04

Transferring ownership to the current owner broke ownership

workspace-members.functions.ts · transferOwnership

ACCOUNT LOCKOUT

Handing ownership over does two things: promote the new owner, then demote the old one. If somebody picked the person who *already* owned the workspace, the second step undid the first.

The company record would still point at that person as owner, but their actual permission level would read “admin”. **The owner would be locked out of owner-only actions in their own company.**

05

Bulk imports jammed halfway through

extract-core.server.ts & the batch page

WORK LOST MID-BATCH

A 25-image import finished 18 and left 7 stuck. The images had already been read correctly — the database writes were fighting each other and losing.

Worse, the code that was supposed to mark a row as failed could *itself* lose that fight, leaving rows with no status and no owner at all.

Four changes fixed it: longer, smarter retries; protected failure paths; fewer simultaneous workers; and collapsing repeated batch-count updates into one. **The next 25-image run completed 25 of 25.**

The same mistakes, in different places

Once the first few were found, the same shapes kept turning up. Grouping them this way is more useful than a flat list — it shows what to watch for next time.

One company could reach another company's records — 7 places

- **Commission rates** could be edited by ID alone, with no check that the rate belonged to your company.
- **The overlap check** for a new commission band compared it against *every* company's bands — so another customer's rates could block yours, and a genuine clash in your own could be hidden behind it.
- **Payment records and brand receipts** could be deleted by ID alone.
- **A payout** could be filed into another company's books, because the permission check looked at your company while the record was written to the partner's.
- **Billing requests** could be listed for any company ID the caller sent, with no permission check — invoice amounts, payment references and notes.
- **The payment ledger** — finding 01 above.

The system said “done” when nothing happened — 9 places

- **Editing a brand or a brand rate** reported success even when the database changed nothing.
- **Saving a partner match keyword** was fire-and-forget: it could fail and you would still be told it worked.
- **Changing a member's sign-in email** updated the login but could silently fail to update their profile — so an admin would see the old address and think it had not worked, while the login had already moved.
- **“Send password reset”** reported success whether or not any email was actually sent.
- **Two money reports and two payout runs** — findings 02 and 03 above.

Features that had never worked at all — 7 places

- **“Save view” on All Orders** — could never have worked. A required field was missing from the record it tried to create.
- **Creating a scheduled report** — same missing field, same result.
- **The Pending and Failed status filters** on All Orders always came back empty. The underlying query already restricted results to successful orders, so asking for failed ones asked for something impossible.
- **The Network filter** only listed networks that happened to be on the page you were looking at — and once you picked one, the list shrank to that single option with no way back.
- **Saved views quietly dropped** the Branch and Store filters. You saved a view scoped to one branch, reloaded it later, and got all of them back with no indication anything was lost.
- **Saving an employee** failed if you left the commission field blank.
- **Saving a partner** failed if you left the join date blank.

Wrong data, quietly — 2 places

- **The commission month** was built in a way that only worked if a full date was supplied. Given just a month, it produced an invalid date that matched nothing — so the summary would come back empty, with no error. Not yet triggered in production, but waiting for the first caller who passed a month to a field named “month”.
- **A plan granted by a super admin** kept whatever expiry date was already on the record — often one in the past. The grant registered as already expired and silently did nothing.

Screenshot reading — 4 improvements

- **September orders were being missed.** The date reader expected three-letter months; the page writes “Sept”.
- **The time was being lost** whenever the screenshot software split the date and time onto two lines — which it does, unpredictably.
- **Full-window screenshots failed** because the order code was looked for in the first line only, and on those captures the first line is page furniture.
- **Order codes with a stray space** in them, or split in two, are now read correctly.

Result on a live 25-image batch: **24 of 25 orders read with no paid AI call at all.**

Interface — 2 fixes

- **Dark mode text was invisible** across the dashboard, All Orders and six admin pages. Cards were forced to stay white while the text colour followed the theme — white on white.
- **The “Processing” tile’s label ran underneath its icon.** Seven tiles in one row left too little width for a single long word.

342 automated tests now guard this

Before this work, almost nothing in the backend was tested. The parts that handle money and permissions had no automated checks at all — which is exactly why the problems above survived so long.

AREA	WHAT THE TESTS GUARD	TESTS
Billing & plans	Pricing, credits, refunds, who may change a plan	30
Commissions	Rate bands, month totals, assigning activations	29
Screenshot reading	Every layout and mangling seen in 35 real samples	27
Plan pricing maths	Proration on every kind of plan change	23
Brand earnings	Revenue, cost and margin splits	22
Members & roles	Who may promote, remove or transfer ownership	20
Account recovery	Who may reset another person's sign-in	20
Store IDs	Adding, editing, removing, duplicates	18
Payment ledger	Owed vs paid, settlement states, brand side	18
Payouts	Generation, bulk payment, failure reporting	16
Other	Formatting, rate bands, salary, import queue	71
Screenshot service	Image handling and the reading service itself	28

The tests proved themselves twice while being written. One fix was reported as applied but never actually saved to disk — a test caught it within seconds. Another time, the type checker caught a mistake in a test itself: it used an employee role where a partner role was required.

What has not been done

Being straight about the edges:

Backend coverage is a little over half

- 65 of 120 backend endpoints now have tests. The money and permission ones were done first, on purpose — that is where a mistake costs the most.
- 55 remain, mostly employees, reports, partners and workspace settings. A companion document lists them file by file.

Two questions only you can answer

- “Registered Number” appeared on one screenshot out of 35, where “Alternate Contact” normally sits — and its value was the same number as the order’s own. It is deliberately left unread until somebody confirms what that field means.
- Duplicate detection relies on a database column that nothing in this codebase ever fills in. If no database rule fills it, duplicate detection has never actually worked. Worth checking.

Not visually checked

- The dark-mode and layout fixes pass the type checker and the tests, but **nobody has looked at them in a browser yet**. Worth a glance after deploying.
- Around 30 chart labels on the dashboard still use fixed colours. Some sit on coloured chart shapes where that is correct, so they need checking one by one rather than changing in bulk.